

# HotelSec PolicyForge AI

Analizador de madurez, riesgos y políticas de ciberseguridad para hoteles de Lanzarote

|           |                                                                                      |
|-----------|--------------------------------------------------------------------------------------|
| Práctica  | Práctica 1 - Desarrollo de herramienta de ciberseguridad con Inteligencia Artificial |
| Línea     | Normativa y Cumplimiento                                                             |
| Enfoque   | Hoteles, alojamientos turísticos y pymes del sector turístico de Lanzarote           |
| Resultado | Dashboard web, evaluador de madurez, generador IA de políticas e informe PDF         |

Documento redactado en primera persona para presentar la idea inicial del proyecto, justificar su encaje con la práctica y explicar las funcionalidades y herramientas previstas.

## 1. Presentación del proyecto

Mi proyecto se llama HotelSec PolicyForge AI. La idea consiste en desarrollar una plataforma web de ciberseguridad orientada a hoteles, alojamientos turísticos y pequeñas empresas del sector turístico de Lanzarote.

El objetivo principal es que una empresa pueda introducir información sobre su situación actual, sus sistemas tecnológicos, sus procesos con datos personales y sus medidas de seguridad, y que la plataforma genere automáticamente un diagnóstico inicial de madurez, un mapa de riesgos, recomendaciones priorizadas y un paquete de políticas de seguridad adaptadas al negocio.

No quiero que sea simplemente una herramienta que genere documentos con IA. Mi objetivo es crear una solución funcional que ayude a una pyme turística a entender sus riesgos reales y a empezar a organizar su seguridad de una forma práctica, visual y comprensible.

## 2. Justificación

He elegido este proyecto porque el sector turístico depende cada vez más de sistemas digitales: reservas online, plataformas externas, TPV, correo electrónico, redes WiFi para clientes, sistemas de facturación, cámaras, cerraduras inteligentes y aplicaciones en la nube.

En el caso de hoteles y alojamientos de Lanzarote, muchos negocios son pequeñas o medianas empresas que no siempre tienen un departamento interno de ciberseguridad. Sin embargo, tratan datos personales de clientes, documentos de identidad, datos de pago, información de reservas y comunicaciones con proveedores.

Esto hace que estén expuestos a riesgos como phishing, ransomware, robo de credenciales, fuga de datos personales, mala gestión de copias de seguridad, accesos compartidos, WiFi mal segmentada o incumplimientos básicos del RGPD.

## 3. Encaje con la práctica

El proyecto encaja dentro de la línea de Normativa y Cumplimiento de la práctica. Concretamente, combina varias ideas del enunciado:

- Generador de políticas de seguridad con IA.
- Simulador de auditoria de ciberseguridad.
- Gestor de riesgos de seguridad con IA.
- Generador de planes de continuidad y respuesta a incidentes.
- Recomendador basico de medidas alineadas con RGPD e ISO 27001.

## 4. Problema que resuelve

El problema principal es que muchas pymes turísticas no saben por donde empezar en ciberseguridad. Pueden tener antivirus o copias de seguridad, pero no disponen de políticas internas, no conocen su nivel de madurez, no tienen un plan de respuesta ante incidentes y no saben priorizar que medidas implantar primero.

- 1 La empresa completa un analizador de perfil.
- 2 La herramienta calcula una puntuación de madurez.
- 3 Se identifican riesgos técnicos, organizativos y normativos.
- 4 La IA genera políticas adaptadas al caso concreto.
- 5 El sistema crea un plan de acción priorizado.
- 6 Se genera un informe PDF profesional.
- 7 El dashboard permite consultar el historial y la evolución.

## 5. Usuarios objetivo

- Hoteles pequeños y medianos.
- Apartahoteles.
- Villas turísticas.
- Hostales y pensiones.
- Empresas de alquiler vacacional.
- Pequeñas agencias turísticas.
- Consultores o proveedores IT que dan soporte a este tipo de empresas.

## 6. Analizador de empresa

El analizador no se limita a preguntar el sector y el numero de empleados. Incluye campos especificos para el contexto hotelero, lo que permite que la IA genere resultados mucho más concretos.

| Area                    | Campos principales                                                                                                                            |
|-------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|
| Perfil del negocio      | Nombre, municipio, tipo de alojamiento, habitaciones, empleados fijos, empleados temporales, temporada alta/baja, proveedor IT.               |
| Sistemas tecnológicos   | PMS, channel manager, motor de reservas, Booking/Airbnb/Expedia, TPV, pagos online, facturación, correo, nube, web propia, CRM.               |
| Seguridad actual        | MFA, gestor de contraseñas, cuentas compartidas, backups, pruebas de restauracion, antivirus/EDR, firewall, actualizaciones, WiFi separada.   |
| Datos personales y RGPD | Pasaportes, DNI, datos de pago, menores, conservacion, proveedores, contratos, registro de actividades y protocolo de brechas.                |
| Riesgo operativo        | Caída de reservas, perdida de correo, ransomware, operación sin internet, check-in manual, responsable de incidentes, tiempo de respuesta IT. |
| Personal                | Formacion en phishing, empleados temporales, revocacion de accesos, dispositivos personales, WhatsApp o mensajería con datos de clientes.     |
| IoT e instalaciones     | CCTV, cerraduras electrónicas, domotica, tablets, kioscos de check-in y control horario.                                                      |

## 7. Funcionalidades principales

| Funcionalidad                    | Descripción                                                                                                                                         |
|----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| Dashboard principal              | Muestra puntuación global, nivel de riesgo, riesgos críticos, políticas generadas, tareas pendientes, últimos analisis y estado del plan de acción. |
| Evaluador de madurez             | Calcula una puntuación de 0 a 100 y la divide por areas: identidad, datos, backups, red, dispositivos, personal, incidentes y continuidad.          |
| Mapa de riesgos                  | Identifica riesgos con descripción, causa probable, impacto, probabilidad, prioridad y medida recomendada.                                          |
| Generador de políticas con IA    | Crea políticas adaptadas sobre contraseñas, backups, dispositivos, teletrabajo, WiFi, PMS, proveedores, incidentes y protección de datos.           |
| Recomendaciones RGPD e ISO 27001 | Ofrece recomendaciones iniciales de cumplimiento, dejando claro que no sustituye una auditoria ni una certificación oficial.                        |
| Plan de acción                   | Divide las medidas en acciones inmediatas, 30 días, 90 días y mejoras a medio plazo, con prioridad, dificultad, impacto y responsable sugerido.     |
| Informe PDF                      | Genera un documento profesional con resumen ejecutivo, perfil del hotel, puntuación, riesgos, políticas, recomendaciones y conclusiones.            |
| Historial                        | Guarda los analisis de cada empresa para comparar la evolucion de su madurez de seguridad.                                                          |

## 8. Arquitectura propuesta

| Capa            | Responsabilidad                                                                        |
|-----------------|----------------------------------------------------------------------------------------|
| Usuario / hotel | Introduce información de la empresa y consulta resultados.                             |
| Frontend web    | Formulario por pasos, dashboard, tablas de riesgos, historial y descarga de informes.  |
| Backend API     | Gestiona usuarios, empresas, analisis, reglas, llamadas a IA y generación de informes. |
| Motor de reglas | Calcula puntuaciones, severidades y prioridades con criterios controlados.             |
| Motor IA        | Genera políticas, recomendaciones, resumen ejecutivo y texto del informe.              |
| Base de datos   | Almacena usuarios, perfiles, respuestas, puntuaciones, riesgos, políticas e informes.  |
| PDF / dashboard | Presenta los resultados de forma visual y descargable.                                 |

## 9. Stack tecnico propuesto

| Area          | Herramientas que voy a utilizar                                                                                            | Motivo                                                                                                       |
|---------------|----------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| Frontend      | React, Vite, TypeScript, Tailwind CSS, React Router, React Hook Form, Zod, Recharts, Lucide React, Axios o TanStack Query. | Permite crear una interfaz moderna, rápida y mantenible, con formularios robustos y dashboard visual.        |
| Backend       | Python, FastAPI, Pydantic, SQLAlchemy, Alembic, JWT, bcrypt o Passlib.                                                     | FastAPI es ligero, rápido, documenta la API automáticamente y encaja bien con servicios de IA.               |
| Base de datos | PostgreSQL.                                                                                                                | Es robusta, profesional y adecuada para guardar usuarios, empresas, analisis, riesgos, políticas e informes. |
| IA            | OpenAI API o modelo local con Ollama, prompts estructurados, plantillas y motor de reglas.                                 | La IA genera textos adaptados, mientras que las reglas aportan consistencia a puntuaciones y riesgos.        |
| PDF           | ReportLab o WeasyPrint.                                                                                                    | Permite generar informes profesionales descargables desde la propia herramienta.                             |
| Despliegue    | Hetzner Cloud VPS, Docker, Docker Compose, Nginx, Let's Encrypt.                                                           | Cumple el requisito de despliegue real y permite publicar la aplicacion con HTTPS.                           |
| Repositorio   | GitHub, README, ramas, commits por fases y .env.example.                                                                   | Facilita la evaluación del historial de desarrollo y la organizacion del proyecto.                           |
| Seguridad     | HTTPS, JWT, hash de contraseñas, validacion de entrada, variables de entorno, rate limiting, logs y backups.               | Protege la propia herramienta y demuestra buenas practicas de desarrollo seguro.                             |

## 10. Estructura del repositorio

La estructura inicial del repositorio podría ser la siguiente:

| Ruta               | Contenido                                                                  |
|--------------------|----------------------------------------------------------------------------|
| frontend/          | Aplicacion React con Vite y TypeScript.                                    |
| backend/           | API FastAPI, modelos, rutas, servicios, motor de scoring e integración IA. |
| docs/              | Documentacion, capturas, diagramas y evidencias del desarrollo.            |
| docker-compose.yml | Orquestacion de frontend, backend, base de datos y proxy.                  |
| .env.example       | Variables necesarias sin exponer secretos reales.                          |
| README.md          | Descripción del proyecto, instalacion, uso y despliegue.                   |

## 11. Seguridad de la propia herramienta

Ademas de analizar la seguridad de hoteles, la propia plataforma debe estar protegida. Por eso incorporare medidas de desarrollo seguro desde el inicio:

- HTTPS obligatorio en produccion.
- Autenticación mediante JWT.
- Hash seguro de contraseñas.
- Variables de entorno para claves y secretos.
- Validacion de datos en frontend y backend.
- Control basico de roles.
- Rate limiting en endpoints sensibles.
- Logs de actividad.
- Copias de seguridad de la base de datos.

## 12. Roadmap para la Práctica 2

| Mejora                    | Descripción                                                                           |
|---------------------------|---------------------------------------------------------------------------------------|
| RAG con fuentes oficiales | Integrar documentacion de INCIBE, AEPD, ISO 27001 o NIST para enriquecer respuestas.  |
| Simulador de incidentes   | Escenarios como ransomware, phishing, caida de reservas o fuga de pasaportes.         |
| Evaluación de proveedores | Cuestionarios y scorecards para proveedores IT, PMS, marketing o mantenimiento.       |
| Comparativa mensual       | Evolucion historica de madurez y reduccion de riesgos.                                |
| Módulo de formacion       | Contenido adaptado para recepcion, direccion, administracion y personal temporal.     |
| Multidioma                | Español, inglés y alemán para hacerlo más util en el contexto turístico de Lanzarote. |
| Escaneo externo basico    | Revision inicial de dominio, HTTPS, cabeceras y exposicion publica.                   |

## 13. Conclusion

HotelSec PolicyForge AI es una propuesta realista y alineada con los requisitos de la práctica. Combina desarrollo web, inteligencia artificial, ciberseguridad, normativa, gestión de riesgos, generación documental y despliegue real.

La herramienta tiene un caso de uso concreto: ayudar a hoteles y pymes turísticas de Lanzarote a conocer su nivel inicial de ciberseguridad y obtener políticas y recomendaciones adaptadas a su situación.

Considero que es un proyecto adecuado para la Práctica 1 porque permite construir una versión funcional en el plazo disponible y, al mismo tiempo, deja margen para ampliar la herramienta en una Práctica 2 con funcionalidades más avanzadas.